

Тема 5. Списки контроля доступа ACL: стандартные ACL и защита управл

Цель лекции

Понимать, где применяются ACL и почему созданный список ещё не фильтрует трафик

Объяснять порядок обработки ACE сверху вниз и действие `implicit deny`

Создавать стандартные IPv4 ACL по Source IP с `wildcard mask`, `host` и `any`

Защищать SSH-доступ к Cisco-устройству через `access-class` на VTY

Выбирать место и направление применения ACL и проверять результат по `matches`

Учебные вопросы

1. Фильтрация трафика и безопасность на L3/L4 с помощью ACL
2. Последовательная обработка правил сверху вниз
3. Неявный запрет `implicit deny`
4. Стандартные ACL по Source IP и обзор расширенных ACL
5. Размещение стандартных ACL ближе к получателю, расширенных — ближе к источнику

1. ACL описывает, какой трафик разрешить или запретить

ACL (Access Control List) — список правил фильтрации трафика на сетевом устройстве

ACE (Access Control Entry) — отдельная строка ACL с действием permit или deny

ACL может ограничивать доступ между подсетями, к серверным VLAN или к управлению устройством

ACL как семейство механизмов может проверять параметры L3 и L4

В этой лекции основной объект настройки — стандартная IPv4 ACL

ACL не заменяет полноценный firewall

ACL является статическим списком правил без глубокого анализа приложений

Обычная ACL не отслеживает состояние соединения как stateful firewall

ACL хорошо подходит для базового разграничения и защиты административного доступа

Для периметра предприятия обычно используют firewall, NAT, VPN и централизованное журналирование

На сетевых устройствах ACL должна быть простой, понятной и документированной

Схема: ACL как фильтр на интерфейсе маршрутизатора

ACL не действует сама по себе. Она начинает фильтровать трафик, только когда применяется к интерфейсу с помощью `ip access-group`.



КЛЮЧЕВЫЕ ВЫВОДЫ

ACL — это фильтр. Он применяет правила к проходящим пакетам.

Где применили — там и фильтрует. Без `ip access-group` ACL не влияет на трафик.

Первое совпадение решает. ACL читается сверху вниз, далее не проверяется.

Implicit deny в конце. Всё, что не разрешено, будет отброшено.

2. ACL читается сверху вниз до первого совпадения

Маршрутизатор проверяет пакет по ACE сверху вниз
Если пакет совпал со строкой, выполняется permit или deny

После первого совпадения нижние строки уже не анализируются

Более конкретные разрешения обычно ставят выше общих запретов

Счётчики matches помогают понять, какая строка реально сработала

Пример ошибки порядка правил

``deny 192.168.10.0 0.0.0.255`` запрещает всю пользовательскую VLAN

Пакет от 192.168.10.50 совпадает с этим deny и сразу отбрасывается

Если ниже написать ``permit host 192.168.10.50``, это разрешение уже не сработает

Правильнее сначала разрешить исключение, затем запретить остальную подсеть

Порядок ACE важен не меньше, чем сами адреса в правилах

3. В конце любой ACL есть `implicit deny`

`Implicit deny` — неявное правило запрета в конце ACL

Для стандартной IPv4 ACL логически действует ``deny any``

Для расширенной IPv4 ACL логический вариант выглядит как ``deny ip any any``

Это правило не отображается как обычная строка, но применяется после последней ACE

Если не добавить `permit` для нужного трафика, он будет отброшен

ACL начинает фильтровать только после применения

Можно создать ACL, и она будет просто храниться в конфигурации

Без ``access-class`` на VTY или ``ip access-group`` на интерфейсе она не влияет на трафик

Implicit deny действует только там, где ACL реально применена

ACL ``MGMT_ONLY`` без ``access-class MGMT_ONLY in`` не защитит SSH

ACL ``BLOCK_VLAN40`` без ``ip access-group`` не отфильтрует интерфейсный трафик

deny any log нужен для диагностики, но не всегда обязателен

Явная строка ``deny any log`` показывает запрещённые попытки в журнале

Implicit deny уже существует даже без явной строки deny

Опция log создаёт сообщения при совпадениях с ACE

На загруженном интерфейсе ``deny any log`` может увеличить нагрузку на CPU и Syslog

Для VTY-трафика объём обычно небольшой, поэтому log приемлем в учебной сети

Диаграмма: порядок обработки ACL и implicit deny



ACL проверяется сверху вниз. Как только найдено первое совпадение, выполняется действие **permit** или **deny**, и дальнейшие строки уже не анализируются.

Пакеты на входе

Пакет А
Источник:
192.168.10.50

Совпадает со строкой 10
→ **PERMIT**

Пакет В
Источник:
192.168.10.77

Не совпадает со строкой 10,
совпадает со строкой 20
→ **DENY**

Пакет С
Источник:
192.168.30.10

Нет совпадений ни с одной
явной строкой → **implicit deny**
→ **DENY**

Пример ACL

10	permit host 192.168.10.50	✓ PERMIT
20	deny 192.168.10.0 0.0.0.255	✗ DENY
30	permit 192.168.20.0 0.0.0.255	✓ PERMIT
...		
implicit deny any		✗ DENY

неявное правило в конце



Что важно понять

- 1 ACL = список правил, ACE = отдельная строка
- 2 Проверка идет только **сверху вниз**
- 3 Решает **первое совпадение**
- 4 Если совпадений нет — срабатывает **implicit deny**



Типичная ошибка

10	deny 192.168.10.0 0.0.0.255
20	permit host 192.168.10.50

✗ Разрешение ниже уже не сработает, потому что пакет будет отброшен раньше.



Исключения размещают выше общих запретов.

Легенда

- ✓ = **permit** / трафик разрешен
- ✗ = **deny** / трафик запрещен
- - - → = переход к следующей строке

Wildcard mask показывает совпадающие и игнорируемые биты

Wildcard mask показывает, какие биты адреса сравниваются, а какие игнорируются

0 в wildcard означает строго сравнивать бит

1 в wildcard означает игнорировать бит

Для обычных непрерывных масок wildcard можно считать вычитанием из 255

Сеть 192.168.10.0/24 записывается как `192.168.10.0
0.0.0.255`

host, сеть и any имеют эквивалентные записи

`permit 192.168.99.50 0.0.0.0` разрешает один конкретный адрес

`permit host 192.168.99.50` делает то же самое короче

`permit 192.168.99.0 0.0.0.255` разрешает всю подсеть /24

`permit any` эквивалентно `permit 0.0.0.0 255.255.255.255`

Такие сокращения нужно читать как обычные wildcard-условия

Стандартные ACL бывают нумерованные и именованные

Нумерованные стандартные ACL обычно используют диапазоны 1-99 и 1300-1999

Именованные ACL легче читать и сопровождать

``ip access-list standard MGMT_ONLY`` создаёт именованную стандартную ACL

Внутри named ACL можно добавлять ACE с sequence numbers

Для обучения лучше использовать имена, отражающие назначение фильтра

4. Стандартная ACL фильтрует только Source IP

Стандартная ACL не видит адрес назначения, TCP-порт или тип приложения

Она отвечает только на вопрос: откуда пришёл трафик
`permit 192.168.99.0 0.0.0.255` разрешает источники из Management VLAN

Если нужно разрешить HTTP к серверу, а SSH запретить, понадобится расширенная ACL

Стандартная ACL хорошо подходит для защиты VTY и простого ограничения источников

Standard и Extended ACL отличаются глубиной проверки

Standard ACL проверяет только Source IPv4 Address

Extended ACL дополнительно может учитывать Source, Destination, Protocol и Ports

В этой лекции Extended ACL нужна только как сравнение и мост к следующей теме

Полная настройка Extended ACL изучается отдельно

Главный практический навык этой лекции — стандартная IPv4 ACL и защита управления

Стандартная ACL для защиты SSH-управления

Задача: разрешить SSH к R1 только из Management VLAN 192.168.99.0/24

Пользовательская VLAN 192.168.40.0/24 не должна подключаться к CLI устройства

ACL создаётся как именованный standard list
`MGMT\_ONLY`

Сама ACL не защищает SSH, пока не применена к VTY через `access-class`

SSH из Management VLAN должен проходить, а SSH из User VLAN должен отклоняться

Минимальная подготовка SSH перед access-class

```
R1(config)# hostname R1
```

```
R1(config)# ip domain-name company.test
```

```
R1(config)# username admin privilege 15 secret
```

```
<StrongPassword>
```

```
R1(config)# crypto key generate rsa modulus 2048
```

```
R1(config)# ip ssh version 2
```

Если IOS не принимает `modulus` в одну строку, введите `crypto key generate rsa` и укажите 2048 в диалоге

access-class защищает VTY, а не интерфейсный трафик

VTY (Virtual Teletype) — удалённые линии CLI-доступа
Telnet или SSH

Для VTY применяется команда `access-class`, а не `ip
access-group`

`access-class MGMT\_ONLY in` ограничивает источники,
которым разрешён вход на VTY

`transport input ssh` запрещает Telnet и оставляет
только SSH

`login local` включает проверку по локальной базе
пользователей

Защищать нужно все существующие VTY-линии

На одних устройствах доступны только `line vty 0 4`

На многих Cisco IOS есть дополнительные `line vty 5 15`

Если защитить только 0 4, оставшиеся VTY могут остаться без access-class

Перед настройкой проверяют `show running-config | section line vty`

Одинаковые параметры SSH, login local и access-class применяют ко всем используемым диапазонам

ACL MGMT_ONLY создаётся отдельным блоком

```
R1(config)# ip access-list standard MGMT_ONLY
```

```
R1(config-std-nacl)# remark SSH only from Management  
VLAN
```

```
R1(config-std-nacl)# 10 permit 192.168.99.0 0.0.0.255
```

```
R1(config-std-nacl)# 20 deny any log
```

ACL создана, но ещё не защищает VTY до применения
через access-class

MGMT_ONLY применяется к VTY 0 4

```
R1(config)# line vty 0 4
```

```
R1(config-line)# login local
```

```
R1(config-line)# transport input ssh
```

```
R1(config-line)# access-class MGMT_ONLY in
```

После применения нужно открыть новую SSH-сессию
из Management VLAN

Существующая SSH-сессия не всегда показывает
эффект новой ACL

MGMT_ONLY нужно повторить для VTY 5 15

```
R1(config)# line vty 5 15
```

```
R1(config-line)# login local
```

```
R1(config-line)# transport input ssh
```

```
R1(config-line)# access-class MGMT_ONLY in
```

Если диапазона 5 15 на устройстве нет, этот шаг пропускают

Главное правило: все существующие VTY-линии должны быть защищены

Нумерованная ACL тоже может защитить VTY

`access-list 10 permit 192.168.99.0 0.0.0.255` создаёт стандартную ACL номер 10

`line vty 0 4` открывает диапазон VTY-линий

`access-class 10 in` применяет список к входящим подключениям управления

`transport input ssh` оставляет только SSH

Именованный вариант удобнее сопровождать, но нумерованный важно уметь читать

Диаграмма: порядок обработки ACL и implicit deny



ACL проверяется сверху вниз. Как только найдено первое совпадение, выполняется действие **permit** или **deny**, и дальнейшие строки уже не анализируются.

Пакеты на входе

Пакет А
Источник:
192.168.10.50

Совпадает со строкой 10
→ **PERMIT**

Пакет В
Источник:
192.168.10.77

Не совпадает со строкой 10,
совпадает со строкой 20
→ **DENY**

Пакет С
Источник:
192.168.30.10

Нет совпадений ни с одной
явной строкой → **implicit deny**
→ **DENY**

Пример ACL

10	permit host 192.168.10.50	✓ PERMIT
20	deny 192.168.10.0 0.0.0.255	✗ DENY
30	permit 192.168.20.0 0.0.0.255	✓ PERMIT
...		
implicit deny any		✗ DENY

неявное правило в конце



Что важно понять

- 1 ACL = список правил, ACE = отдельная строка
- 2 Проверка идет только **сверху вниз**
- 3 Решает **первое совпадение**
- 4 Если совпадений нет — срабатывает **implicit deny**



Типичная ошибка

10	deny 192.168.10.0 0.0.0.255
20	permit host 192.168.10.50

✗ Разрешение ниже уже не сработает, потому что пакет будет отброшен раньше.



Исключения размещают выше общих запретов.

Легенда

- ✓ = **permit** / трафик разрешен
- ✗ = **deny** / трафик запрещен
- - - - - → = переход к следующей строке

Проверка VTY-защиты

`show running-config | section line vty` показывает настройки VTY

В выводе должны быть `login local`, `transport input ssh` и `access-class MGMT\_ONLY in`

SSH из Management VLAN должен открывать CLI-доступ

SSH из User VLAN 192.168.40.0/24 должен быть отклонён

Проверка выполняется новой SSH-сессией, а не старым уже открытым подключением

Счётчики matches показывают реальное совпадение с ACE

```
R1# show ip access-lists MGMT_ONLY
```

```
Standard IP access list MGMT_ONLY
```

```
10 permit 192.168.99.0, wildcard bits 0.0.0.255 (5  
matches)
```

```
20 deny any log (2 matches)
```

matches показывает количество совпадений с
конкретной ACE

Если счётчик не меняется, трафик не проходит через
эту ACL или совпадает с другой строкой

Если счётчик не меняется, проверяют путь трафика

ACL могла быть создана, но не применена

ACL применена не к тому интерфейсу или VTY-диапазону

Пакет совпал с более ранней ACE

Тестируется уже существующая SSH-сессия, а не новое подключение

Соединение блокируется раньше другой ACL или нет маршрута до устройства

Source IP может отличаться из-за NAT или jump host

5. Стандартные ACL обычно размещают ближе к получателю

Стандартная ACL знает только Source IP и не знает конечное назначение трафика

Если поставить её близко к источнику, можно случайно запретить этому источнику все направления
Размещение ближе к получателю ограничивает доступ именно к нужному ресурсу или сегменту

Это практическое правило, а не синтаксическое требование Cisco IOS

Для VTY правило реализуется особенно удобно: ACL применяется на линиях управления конкретного устройства

Extended ACL обычно размещают ближе к источнику

Extended ACL умеет учитывать destination, protocol и port

Поэтому она может точнее запретить только нужный тип трафика

Такую ACL обычно ставят ближе к источнику, чтобы не гонять запрещённый трафик через сеть

В этой лекции это только принцип placement

Настройка Extended ACL будет изучаться в следующей лекции

access-class и ip access-group имеют разный контекст

`ip access-group ACL in` на L3-интерфейсе проверяет пакет, входящий через интерфейс

`ip access-group ACL out` проверяет пакет, выходящий из интерфейса

`access-class ACL in` на VTY проверяет удалённого пользователя, который подключается к CLI

`access-class ACL out` ограничивает исходящие подключения из VTY-сессии и используется редко

Для защиты SSH нужен именно `access-class MGMT\_ONLY in`

Интерфейсное применение ACL требует направления

`ip access-group ACL\_NAME in` применяет ACL на входящих пакетах интерфейса

`ip access-group ACL\_NAME out` применяет ACL на исходящих пакетах интерфейса

Направление выбирается относительно самого интерфейса маршрутизатора

Ошибочное направление — классическая причина, почему ACL не работает как ожидается

Для VTU используется access-class, поэтому in означает вход в линии управления

Стандартная ACL для запрета VLAN 40 к серверной VLAN 30

```
R1(config)# ip access-list standard BLOCK_VLAN40
```

```
R1(config-std-nacl)# 10 deny 192.168.40.0 0.0.0.255
```

```
R1(config-std-nacl)# 20 permit any
```

```
R1(config)# interface Vlan30
```

```
R1(config-if)# ip access-group BLOCK_VLAN40 out
```

Если используется routed interface или subinterface,
команда применяется на соответствующем L3-
интерфейсе

Почему ACL для VLAN 40 ставят на выход к VLAN 30

Путь: VLAN 40 → маршрутизатор → Vlan30 OUT →
Server VLAN

ACL out на Vlan30 блокирует доступ VLAN 40 именно к серверной VLAN

Доступ VLAN 40 к другим направлениям при этом не блокируется

Стандартная ACL запрещает всю VLAN 40, но не умеет выбрать один сервер или порт

Для политики вида запретить только определённый протокол нужна Extended ACL из следующей лекции

Диаграмма: где размещать стандартную ACL

Стандартная ACL проверяет только **Source IP**. Размещайте её ближе к **месту назначения**, чтобы не блокировать нужный трафик раньше времени.



Главное правило

Стандартную ACL ставим как можно ближе к получателю трафика, на интерфейсе, через который трафик входит в сеть получателя.

ПРАВИЛЬНО: ближе к получателю



Размещаем ACL на интерфейсе R2, который ведёт к сети назначения 10.10.10.0/24. Так мы не блокируем другие потоки по пути.

Цель: защитить сервер 10.10.10.10



Стандартная ACL 10

```
10 deny 192.168.1.50 0.0.0.0
20 permit any
(implicit deny в конце списка)
```

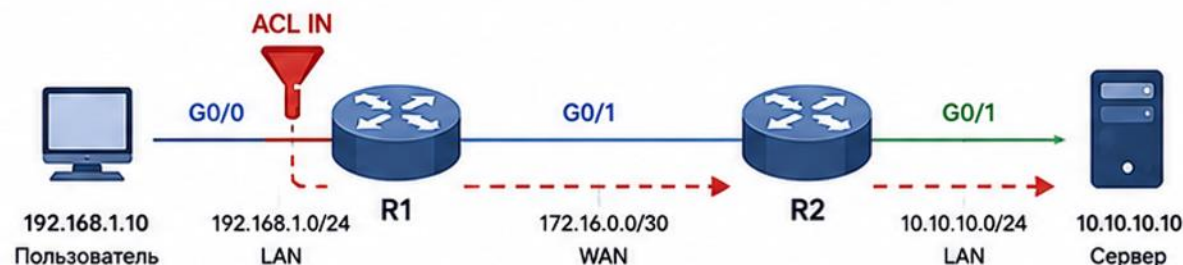
Как это работает

Фильтруем только те пакеты, которые уже дошли до сети назначения 10.10.10.0/24. Остальной трафик по пути (например, в интернет или другие сети) не затрагивается.

НЕПРАВИЛЬНО: слишком далеко от получателя



Если поставить ACL на R1 (на входе из LAN), мы заблокируем трафик к серверу и к другим сетям, куда источник может обращаться.



Стандартная ACL 10

```
10 deny 192.168.1.50 0.0.0.0
20 permit any
(implicit deny в конце списка)
```

Что произойдёт

Будут заблокированы все пакеты от 192.168.1.50 ко всем сетям за R1: не только к серверу 10.10.10.10, но и, например, в интернет или другие подсети.

Кратко о стандартной ACL



Проверяет только Source IP.



Подходит для фильтрации по источнику: блокируем ненужные подсети/адреса.



Размещаем ближе к получателю (destination).

Сравнение стандартной и расширенной ACL

Стандартная ACL	Расширенная ACL
Проверяет только Source IP	Проверяет Source IP, Destination IP, протокол, порты (L4)
Размещаем ближе к получателю	Размещаем ближе к источнику
Нумерованные: 1–99, 1300–1999 или именованные	Нумерованные: 100–199, 2000–2699 или именованные



Как выбрать место для ACL

- ✓ Определите, что является получателем трафика.
- ✓ Найдите интерфейс устройства, через который этот трафик входит в сеть получателя.
- ✓ Применяйте стандартную ACL на входящем направлении (in) этого интерфейса.
- ✓ Проверяйте счётчики: `show access-lists`.



Ошибка места размещения → нежелательная блокировка трафика или избыточная нагрузка на устройство.

Типовые ошибки стандартных ACL

Забыли применить ACL к интерфейсу или VTY

Забыли permit для разрешённого трафика и сработал implicit deny

Неверно посчитали wildcard mask

Применили интерфейсную ACL не в том направлении

Для VTY использовали `ip access-group` вместо `access-class`

Разместили стандартную ACL слишком близко к источнику и заблокировали лишние направления

Правила безопасной работы с ACL

Изменения ACL вступают в силу сразу после ввода команды

Перед применением записывают цель ACL обычным языком

Сначала создают ACL и проверяют строки через ``show access-lists``

Сначала добавляют разрешающее правило для собственного адреса или Management VLAN

ACL управления применяют только при наличии консоли, out-of-band доступа или резервной SSH-сессии

Безопасный порядок применения ACL на управление

1. Проверить SSH, локального пользователя и свой Source IP
2. Подготовить консольный доступ или резервную SSH-сессию
3. Создать ACL и проверить её через `show access-lists`
4. Применить `access-class` ко всем существующим VTY-линиям
5. Открыть новую SSH-сессию с разрешённого адреса
6. Проверить запрещённый адрес и только потом сохранить конфигурацию

Sequence numbers помогают редактировать named ACL

В именованных ACL Cisco IOS показывает номера строк правил

Номер позволяет вставить новое правило между существующими строками

Пример: `10 permit 192.168.99.0 0.0.0.255`, `20 deny any log`

Добавление исключения: `15 permit host 192.168.100.10`

Удаление отдельной ACE: `no 15`

Это безопаснее, чем удалять и пересоздавать весь список во время удалённой работы

remark документирует назначение ACL прямо в конфигурации

`remark` добавляет комментарий внутри ACL

Пример: `remark SSH only from Management VLAN`

Комментарии помогают читать ACL без отдельного документа

remark особенно полезен в длинных ACL

Хорошая практика документирования начинается уже со стандартных ACL

Перед ACL на управление нужен аварийный доступ

Ошибка в access-class может отрезать администратора от SSH

Перед применением ACL нужно иметь консольный доступ или резервную сессию

Сначала проверяют локального пользователя, SSH и Management VLAN

Затем применяют access-class и тестируют вход с разрешённого адреса

Только после проверки запрещённого адреса сохраняют конфигурацию

Документирование стандартной ACL

В документации указывают имя ACL и её назначение
Фиксируют разрешённые source-сети и причины запретов

Отдельно указывают место применения: VTY, интерфейс, направление

Записывают команды проверки и ожидаемый результат

Указывают, какие VTY-диапазоны защищены: 0 4, 5 15 или другой набор

Итоги лекции

ACL состоит из ACE и обрабатывается сверху вниз до первого совпадения

В конце ACL действует `implicit deny`, поэтому нужные `permit` должны быть добавлены явно

Standard IPv4 ACL фильтрует только Source IP и обычно размещается ближе к получателю

``access-class`` защищает VTY, а ``ip access-group`` фильтрует транзитный трафик на L3-интерфейсе

Счётчики `matches` показывают, какие ACE реально сработали

ACL управления применяют только при наличии

Контрольные вопросы

Что такое ACL и ACE?

Как ACL обрабатывает правила сверху вниз?

Что такое `implicit deny`?

Что проверяет Standard IPv4 ACL?

Чем в общем виде Standard ACL отличается от Extended ACL?

Почему Standard ACL обычно размещают ближе к получателю?

Для чего используется `access-class`?

Чем `access-class` отличается от `ip access-group`?

Что показывают счётчики `matches`?